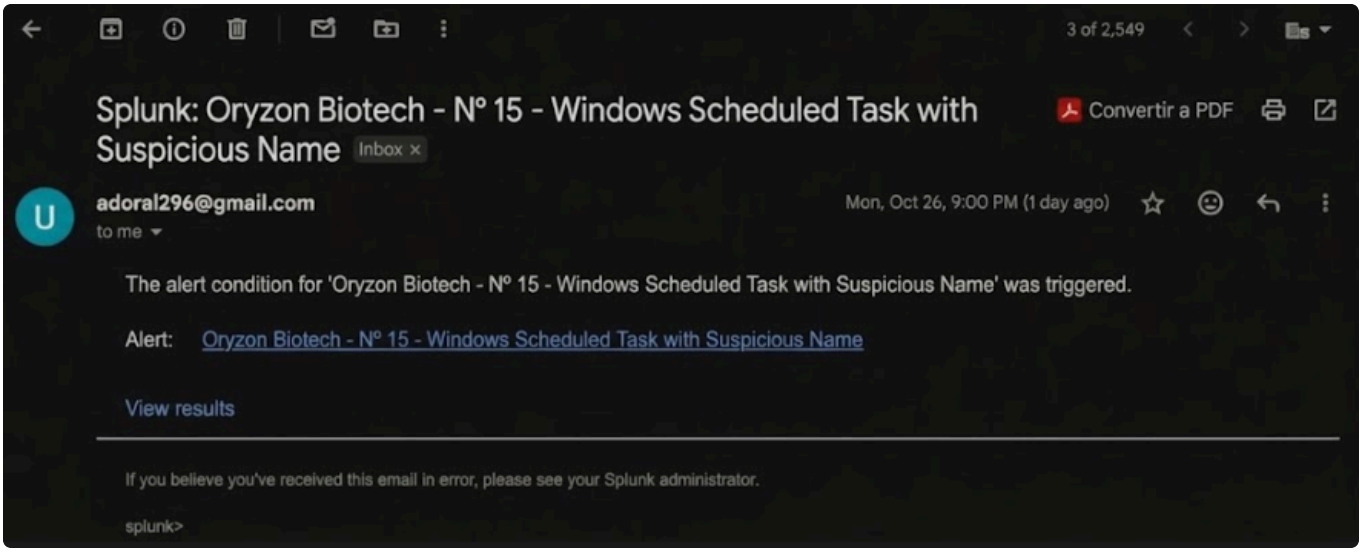
14.Análisis y reducción de falsos positivos en las reglas de detección

En este apartado investigo, ajusto y corrijo una regla de detección de amenazas en Splunk para reducir un falso positivo (las alertas que identifican actividades legítimas como posibles amenazas cuando en realidad no lo son)



La alerta «Oryzon Biotech - Nº 15 - Windows Scheduled Task with Suspicious Name» detecta la creación de tareas programadas en Windows con nombres sospechosos que podrían utilizarse para mantener el acceso a un equipo.

Esta es la consulta SPL de la alerta en Splunk mal diseñada:

```
index=index_agentes_windows host="WindowsSplunkAg" EventCode IN
(4698,4700,4702)
| rex field=Message "Nombre de la tarea:\s+(?<TaskName>[^\r\n]+)"
| rex field=Message "(?s)Contenido de la tarea:\s+(?<TaskContent><\?xml.*?
</Task>)"
| eval TaskName=trim(TaskName)
| eval task_basename=lower(replace(TaskName,"^.*\\\\",""))
| lookup local=t windows_suspicious_tasks task_name as TaskName OUTPUT
tool_type as lookup_tool_type
| eval match_extra=if(task_basename IN (
"windowshealthsync","windowshealthmonitor","windowshealthcache","windowshealth
broker","windowshealthworker","windowshealthagent","windowshealthhelper","wind
owshealthservice","windowshealthreport","windowshealthupdate",
"systemtelemetrysync","systemtelemetrycache","systemtelemetryworker","systemte
lemetrybroker","systemtelemetryagent","systemtelemetryreport","systemtelemetry
update","systemtelemetrycheck","systemtelemetryhost","systemtelemetrymaint",
"diagnosticdatasync","diagnosticdatacache","diagnosticdataworker","diagnosticd
```

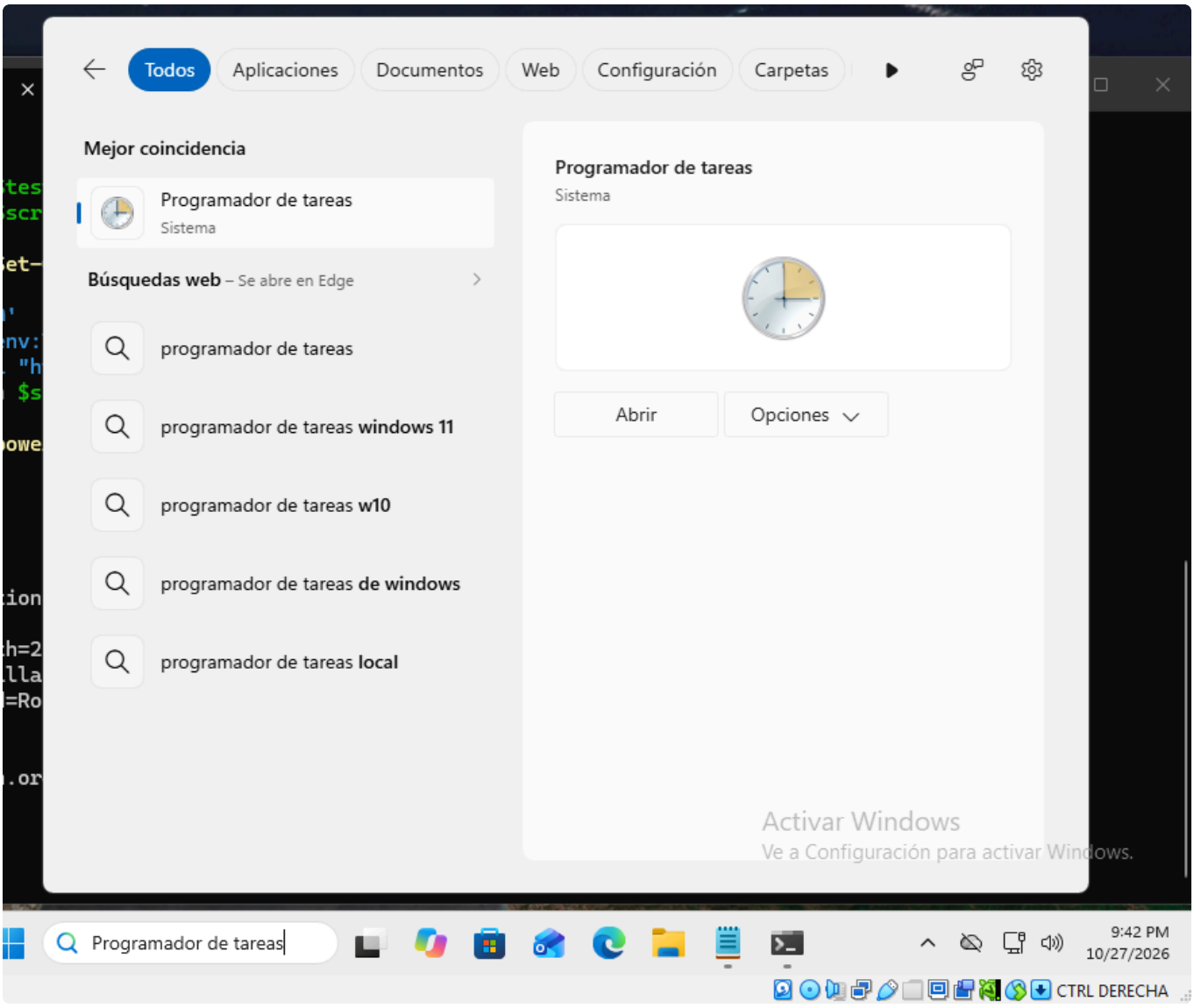
```
atabroker","diagnosticdataagent","diagnosticdatareport","diagnosticdataupdate"
,"diagnosticdatacheck","diagnosticdatahost","diagnosticdatamaint",
"securityhealthsync","securityhealthcache","securityhealthworker","securityhea
lthbroker","securityhealthagent","securityhealthreport","securityhealthupdate"
,"securityhealthcheck","securityhealthhost","securityhealthmaint",
"networkhealthsync","networkhealthcache","networkhealthworker","networkhealthb
roker","networkhealthagent","networkhealthreport","networkhealthupdate","netwo
rkhealthcheck","networkhealthhost","networkhealthmaint",
"compatibilitysync","compatibilitycache","compatibilityworker","compatibilityb
roker","compatibilityagent","compatibilityreport","compatibilityupdate","compa
tibilitycheck","compatibilityhost","compatibilitymaint",
"inventorydatasync","inventorydatacache","inventorydataworker","inventorydatab
roker","inventorydataagent","inventorydatareport","inventorydataupdate","inven
torydatacheck","inventorydatahost","inventorydatamaint",
"updatestatussync","updatestatuscache","updatestatusworker","updatestatusbroke
r","updatestatusagent","updatestatusreport","updatestatuscheck","updatestatush
ost","updatestatusmaint","updatestatusservice",
"backgroundhealthsync","backgroundhealthcache","backgroundhealthworker","backg
roundhealthbroker","backgroundhealthagent","backgroundhealthreport","backgroun
dhealthupdate","backgroundhealthcheck","backgroundhealthhost","backgroundhealt
hmaint",
"remotesupportsync","remotesupportcache","remotesupportworker","remotesupportb
roker","remotesupportagent","remotesupportreport","remotesupportupdate","remot
esupportcheck","remotesupporthost","remotesupportmaint",
"sessionhealthsync","sessionhealthcache","sessionhealthworker","sessionhealthb
roker","sessionhealthagent","sessionhealthreport","sessionhealthupdate","sessi
onhealthcheck","sessionhealthhost","sessionhealthmaint",
"browserhealthsync","browserhealthcache","browserhealthworker","browserhealthb
roker","browserhealthagent","browserhealthreport","browserhealthupdate","brows
erhealthcheck","browserhealthhost","browserhealthmaint",
"credentialhealthsync","credentialhealthcache","credentialhealthworker","crede
ntialhealthbroker","credentialhealthagent","credentialhealthreport","credentia
lhealthupdate","credentialhealthcheck","credentialhealthhost","credentialhealt
hmaint",
"policyhealthsync","policyhealthcache","policyhealthworker","policyhealthbroke
r","policyhealthagent","policyhealthreport","policyhealthupdate","policyhealth
check","policyhealthhost","policyhealthmaint",
"storagehealthsync","storagehealthcache","storagehealthworker","storagehealthb
roker","storagehealthagent","storagehealthreport","storagehealthupdate","stora
gehealthcheck","storagehealthhost","storagehealthmaint",
"backuphealthsync","backuphealthcache","backuphealthworker","backuphealthbroke
r","backuphealthagent","backuphealthreport","backuphealthupdate","backuphealth
check","backuphealthhost","backuphealthmaint",
"deploymenthealthsync","deploymenthealthcache","deploymenthealthworker","deplo
ymenthealthbroker","deploymenthealthagent","deploymenthealthreport","deploymen
thealthupdate","deploymenthealthcheck","deploymenthealthhost","deploymenthealt
```

```
hmaint",
"runtimehealthsync","runtimehealthcache","runtimehealthworker","runtimehealthb
roker","runtimehealthagent","runtimehealthreport","runtimehealthupdate","runti
mehealthcheck","runtimehealthhost","runtimehealthmaint",
"taskstatussync","taskstatuscache","taskstatusworker","taskstatusbroker","task
statusagent","taskstatusreport","taskstatusupdate","taskstatuscheck","taskstat
ushost"
),1,0)
| eval tool_type=if(isnotnull(lookup_tool_type) AND
lookup_tool_type!="",lookup_tool_type,if(match_extra=1,"custom_candidate",null
()))
| where isnotnull(tool_type)
| xmlkv TaskContent
| eval Computer=coalesce(Computer,host)
| table _time EventCode Computer TaskName task_basename tool_type Command
Arguments Author Caller_User_Name
```

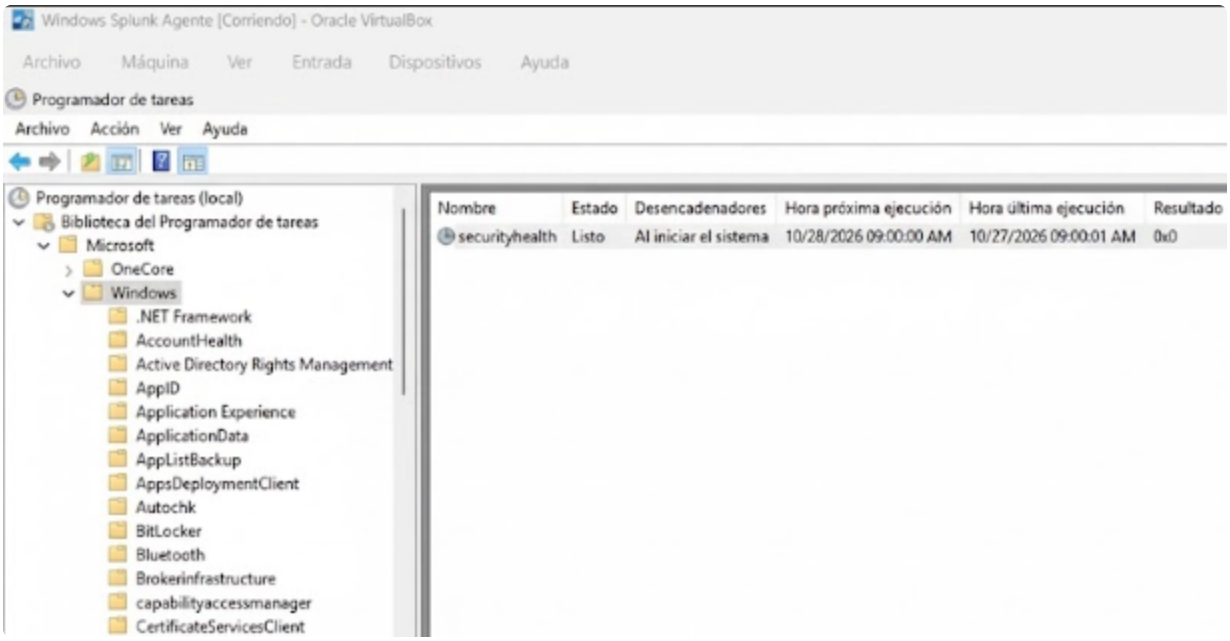
La consulta compara los nombres de las tareas programadas con una lista de patrones sospechosos y muestra las coincidencias para investigar posibles amenazas.

Para localizar el falso positivo, reviso los eventos en la sección **Search** de Splunk e identifico la tarea `SecurityHealth`.

A continuación, abro el Programador de tareas de mi agente Windows para comprobar su origen y determinar si se trata de una actividad legítima:



Me dirijo a > Biblioteca del Programador de tareas >Microsoft > Windows



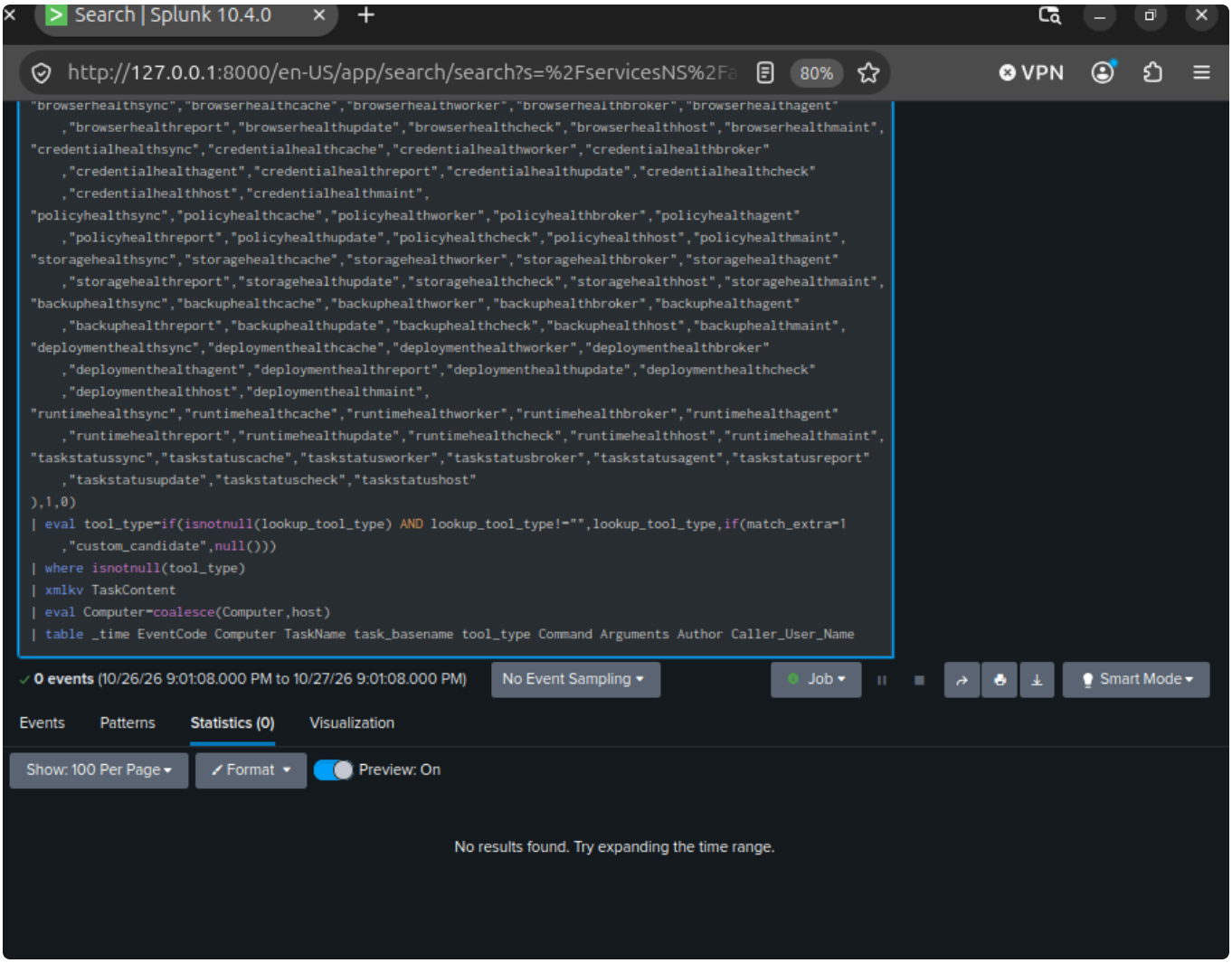
Investigo en Internet, pregunto a la IA y llego a la conclusión que la tarea `SecurityHealth` pertenece a Windows y ejecuta `%windir%\System32\SecurityHealthSystray.exe`, un componente legítimo que muestra el icono de Seguridad de Windows. Por tanto, este falso positivo es en realidad actividad legítima del sistema.

Para corregirlo, accedo a Alerts en Splunk y modifico la consulta SPL de la alerta n.º 15 para excluir del listado de tareas sospechosas esta tarea legítima.

```
index=index_agentes_windows host="WindowsSplunkAg" EventCode IN
(4698,4700,4702)
| rex field=Message "Nombre de la tarea:\s+(?<TaskName>[^\r\n]+)"
| rex field=Message "(?s)Contenido de la tarea:\s+(?<TaskContent><\?xml.*?
</Task>)"
| eval TaskName=trim(TaskName)
| eval task_basename=lower(replace(TaskName,"^.*\\\\","",""))
| where NOT (task_basename IN ("securityhealthsystray","securityhealth"))
| lookup local=t windows_suspicious_tasks task_name as TaskName OUTPUT
tool_type as lookup_tool_type
| eval match_extra=if(task_basename IN (
"windowshealthsync","windowshealthmonitor","windowshealthcache","windowshealth
broker","windowshealthworker","windowshealthagent","windowshealthhelper","wind
owshealthservice","windowshealthreport","windowshealthupdate",
"systemtelemetrysync","systemtelemetrycache","systemtelemetryworker","systemte
lemetrybroker","systemtelemetryagent","systemtelemetryreport","systemtelemetry
update","systemtelemetrycheck","systemtelemetryhost","systemtelemetrymaint",
"diagnosticdatasync","diagnosticdatacache","diagnosticdataworker","diagnosticd
atabroker","diagnosticdataagent","diagnosticdatareport","diagnosticdataupdate"
,"diagnosticdatacheck","diagnosticdatahost","diagnosticdatamaint",
"networkhealthsync","networkhealthcache","networkhealthworker","networkhealthb
roker","networkhealthagent","networkhealthreport","networkhealthupdate","netwo
rkhealthcheck","networkhealthhost","networkhealthmaint",
"compatibilitysync","compatibilitycache","compatibilityworker","compatibilityb
roker","compatibilityagent","compatibilityreport","compatibilityupdate","compa
tibilitycheck","compatibilityhost","compatibilitymaint",
"inventorydatasync","inventorydatacache","inventorydataworker","inventorydatab
roker","inventorydataagent","inventorydatareport","inventorydataupdate","inven
torydatacheck","inventorydatahost","inventorydatamaint",
"updatestatussync","updatestatuscache","updatestatusworker","updatestatusbroke
r","updatestatusagent","updatestatusreport","updatestatuscheck","updatestatush
ost","updatestatusmaint","updatestatusservice",
"backgroundhealthsync","backgroundhealthcache","backgroundhealthworker","backg
roundhealthbroker","backgroundhealthagent","backgroundhealthreport","backgroun
dhealthupdate","backgroundhealthcheck","backgroundhealthhost","backgroundhealt
hmaint",
"remotesupportsync","remotesupportcache","remotesupportworker","remotesupportb
```

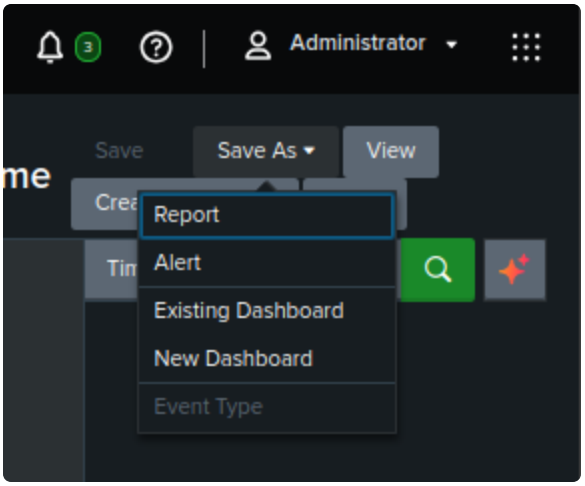
```
roker","remotesupportagent","remotesupportreport","remotesupportupdate","remot
esupportcheck","remotesupporthost","remotesupportmaint",
"sessionhealthsync","sessionhealthcache","sessionhealthworker","sessionhealthb
roker","sessionhealthagent","sessionhealthreport","sessionhealthupdate","sessi
onhealthcheck","sessionhealthhost","sessionhealthmaint",
"browserhealthsync","browserhealthcache","browserhealthworker","browserhealthb
roker","browserhealthagent","browserhealthreport","browserhealthupdate","brows
erhealthcheck","browserhealthhost","browserhealthmaint",
"credentialhealthsync","credentialhealthcache","credentialhealthworker","crede
ntialhealthbroker","credentialhealthagent","credentialhealthreport","credentia
lhealthupdate","credentialhealthcheck","credentialhealthhost","credentialhealt
hmaint",
"policyhealthsync","policyhealthcache","policyhealthworker","policyhealthbroke
r","policyhealthagent","policyhealthreport","policyhealthupdate","policyhealth
check","policyhealthhost","policyhealthmaint",
"storagehealthsync","storagehealthcache","storagehealthworker","storagehealthb
roker","storagehealthagent","storagehealthreport","storagehealthupdate","stora
gehealthcheck","storagehealthhost","storagehealthmaint",
"backuphealthsync","backuphealthcache","backuphealthworker","backuphealthbroke
r","backuphealthagent","backuphealthreport","backuphealthupdate","backuphealth
check","backuphealthhost","backuphealthmaint",
"deploymenthealthsync","deploymenthealthcache","deploymenthealthworker","deplo
ymenthealthbroker","deploymenthealthagent","deploymenthealthreport","deploymen
thealthupdate","deploymenthealthcheck","deploymenthealthhost","deploymenthealt
hmaint",
"runtimehealthsync","runtimehealthcache","runtimehealthworker","runtimehealthb
roker","runtimehealthagent","runtimehealthreport","runtimehealthupdate","runti
mehealthcheck","runtimehealthhost","runtimehealthmaint",
"taskstatussync","taskstatuscache","taskstatusworker","taskstatusbroker","task
statusagent","taskstatusreport","taskstatusupdate","taskstatuscheck","taskstat
ushost"
),1,0)
| eval tool_type=if(isnotnull(lookup_tool_type) AND
lookup_tool_type!="",lookup_tool_type,if(match_extra=1,"custom_candidate",null
()))
| where isnotnull(tool_type)
| xmlkv TaskContent
| eval Computer=coalesce(Computer,host)
| table _time EventCode Computer TaskName task_basename tool_type Command
Arguments Author Caller_User_Name
```

Ejecuto la consulta SPL para ver los cambios:



Ahora no obtengo resultados, así es como debería de ser.

Hago clic en Save para guardar cambios:



Para terminar de comprobar la corrección, creo manualmente la tarea y verifico que Splunk ya no genera la alerta ni envía notificaciones por correo electrónico. Así confirmo que reduzco este falso positivo.

Si en el futuro recibo nuevos falsos positivos parecidos a este, seguiré el mismo proceso de investigación, corrección y verificación para reducir las alertas innecesarias.